Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 3. Estándares de Gestión de la Seguridad y Niveles de Madurez

Índice

Esquema

Ideas clave

3.1. Introducción y objetivos

3.2. El estándar ISO 27001

3.3. Modelos de madurez para la seguridad de la información

3.4. Referencias bibliográficas

A fondo

Vídeos introductorios a ISO 27001

Norma UNE ISO 27001

Web informativa de la familia de estándares ISO 27000

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

3.1. Introducción y objetivos

El objetivo fundamental de este tema es el de conocer los **principales estándares en Gestión de la Seguridad,** encabezados por la familia ISO27000. Este conocimiento es esencial para comprender los conceptos que son necesarios para gestionar adecuadamente la protección de la información.

Más concretamente, los objetivos de este tema son los siguientes:

- Conocer el marco del estándar ISO 27001 y saber aplicar los conceptos de las normas en situaciones prácticas.
- Conocer modelos de madurez en el área de la Seguridad de la Información y saber diferenciarlos entre sí y en relación con los estándares de certificación.

Se introducen los términos y conceptos más relevantes en la gestión de la seguridad de la información, introduciendo conceptos enfocados a los principales estándares y modelos de madurez aplicables en la actualidad.

Después de una lectura rápida del tema, es especialmente importante, por su relevancia como estándar, dedicar tiempo a entender y conocer en detalle el estándar ISO 27000 en lo relativo a su marco conceptual y terminología.

© Universidad Internacional de La Rioja (UNIR)

3.2. El estándar ISO 27001

El estándar UNE-ISO/IEC 27001:2013 **Sistemas de Gestión de la Seguridad de la Información (SGSI). Requisitos** es el primero de la serie de estándares ISO 27000. Es la **norma principal** de la familia, ya que establece los requisitos para la gestión del SGSI y su auditoría.

Antecedentes del estándar ISO 27001: ISO/IEC BS7799

El **Estándar Británico ISO-IEC BS7799-IT** es un código aceptado internacionalmente en la práctica de la seguridad de la información. El estándar aplica un método de **cuatro fases** para implementar una solución de sistemas de administración de seguridad de la información. La norma ISO 27001 puede considerarse como la **última revisión de la norma BS 7799:2002 Parte 2,** de la que ya había en el mundo previamente alrededor de 2.000 certificados.

La familia ISO 27000

La siguiente figura resume las **normas de seguridad de la familia 27000.** Por ejemplo, la norma ISO 27002 detalla los requisitos de la norma 27001, proporcionando una guía de buenas prácticas que describe los objetivos de control y controles en cuanto a seguridad de la información con 14 dominios, 35 objetivos de control y 114 controles. No obstante, ISO 27002 no se considera una norma de certificación como 27001, sino una especificación de apoyo o buenas prácticas.

© Universidad Internacional de La Rioja (UNIR)

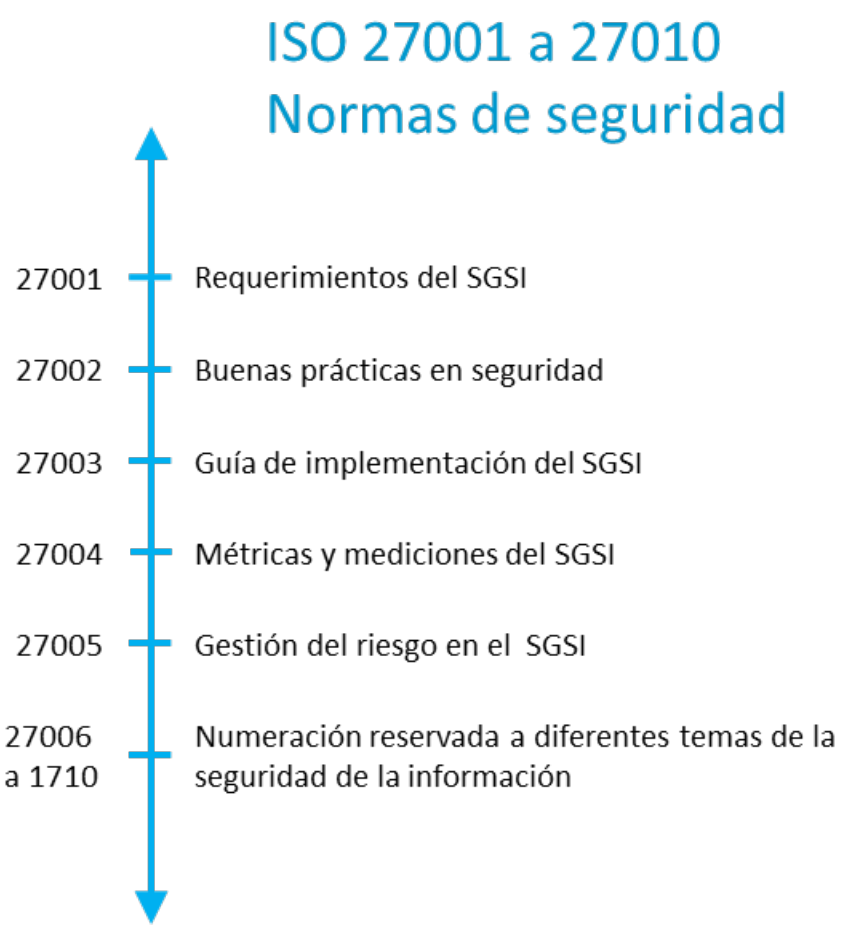


Figura 1. Resumen de las normas de seguridad de la familia 27000. Fuente: elaboración propia.

Por ejemplo, en la ISO 27002 se incluye el siguiente control: «Medios físicos en tránsito: Los medios que contienen información debieran ser protegidos contra accesos no-autorizados, mal uso o corrupción durante el transporte más allá de los límites físicos de una organización» (ISO 27002, 2018). Lógicamente, este control solo deberá diseñarse en caso de que se dé el citado tránsito.

Introducción a la norma 27001

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La norma ISO 27001 describe los requisitos de un Sistema de Gestión de la Seguridad de la Información (SGSI). Proporciona un marco común para la elaboración de las normas de seguridad de cualquier tipo de organización, estableciendo un método de gestión eficaz de la seguridad. Esta norma es la base del proceso de auditoría y certificación de los sistemas de seguridad de información de las organizaciones.

El establecimiento del SGSI se realiza seleccionando una serie de controles elegidos en función de su importancia en la gestión del sistema de seguridad.

La siguiente tabla resume la estructura de la norma y sus principales contenidos.

Plan de mejora personal		
Cap.	**Fortalezas**	**Acciones de mejora**
1	Alcance	Establece el alcance y ámbito de la aplicación de la norma
2	Referencias	Detalla otras normas relacionadas
3	Términos y definiciones	Proporciona las definiciones de la terminología básica
4	Contexto de la organización	Identifica los aspectos relevantes de la organización de cara a la seguridad de la información y se limita el alcance
5	Liderazgo	Establece los requisitos de compromiso de la dirección y de asignación de recursos
6	Planificación	Descripción de los objetivos de seguridad y definición de la gestión de los riesgos
7	Soporte	Dotación de recursos para el establecimiento y mejora del SGSI
8	Operación	Verificación de la operación del SGSI y del estado de los riesgos
9	Evaluación del desempeño	Realización de auditorías internas y revisiones del SGSI
10	Mejora	Gestión de las no conformidades,las acciones correctivas y la mejora continua el

Tabla 1. Resumen de los principales contenidos de la norma y su estructura por capítulo. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

En los procesos de un **sistema de gestión de seguridad de la información** se utiliza con frecuencia el modelo PDCA (Planear, Hacer, Comprobar y Actuar).

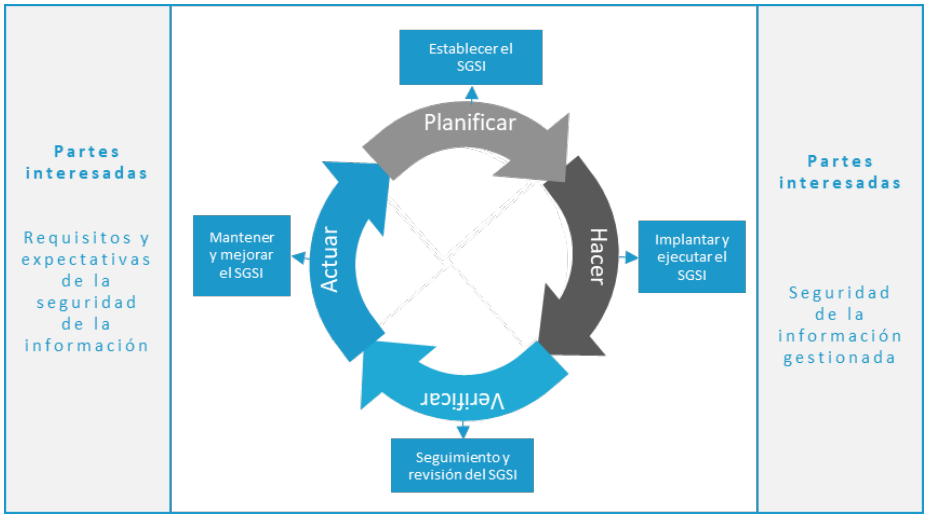


Figura 2. Modelo PDCA en el SGSI. Fuente: elaboración propia.

El proceso de **planificación** comienza con el **diseño inicial del SGSI,** incluyendo la evaluación de riesgos inicial y cómo se tratarán. Comprende las siguientes actividades:

- Definir el alcance del SGSI.
- Definir la política del SGSI.
- Identificar los riesgos.
- Gestionar los riesgos.
- Seleccionar los controles.

Una vez se han diseñado los diferentes mecanismos de gestión (políticas, procedimientos, etc.) se ponen en marcha implantando y **ejecutando** el SGSI. Comprende las siguientes actividades:

-

© Universidad Internacional de La Rioja (UNIR)

Definir e implantar un plan de gestión de riesgos.

- Implantar los controles seleccionados y sus indicadores.
- Implantar el SGSI.

En la **fase de seguimiento y revisión** será cuando se evalúe la marcha de este. Dependiendo del nivel de madurez del SGSI en esta **fase de verificación** se incluirán auditorías (internas o externas). Comprende las siguientes actividades:

- Desarrollar los procedimientos de monitorización.
- Revisar regularmente el SGSI.
- Revisar los niveles de riesgo.
- Auditar el SGSI.

Finalmente, a la luz de la evaluación realizada, **se propondrán las mejoras al SGSI** que pasarán a una **nueva fase de diseño.** Comprende las siguientes actividades:

- Implantar mejoras.
- Adoptar acciones preventivas y correctivas.
- Comunicar acciones y resultados.
- Verificar que las mejoras cumplen su objetivo.

Requisitos generales

La adopción de un sistema de gestión de seguridad de la información es una **decisión estratégica** y se diseña e implanta de forma diferente en cada

© Universidad Internacional de La Rioja (UNIR)

organización. Una organización debe **definir el alcance y los límites del sistema de gestión de seguridad de la información** de acuerdo con las características de la organización, su ubicación, activos y tecnología.

Se deben establecer los objetivos de la política del sistema de gestión de seguridad de la información, identificando los posibles riesgos o amenazas que se podrían producir.

> El alcance del SGSI
>
> En una organización pequeña, puede que el alcance del SGSI sea toda la organización. No obstante, en organizaciones grandes no tiene por qué ser así. Por ejemplo, puede que le alcance en una empresa de venta por internet abarca la parte de Comercio electrónico, pero no el aprovisionamiento (si éste se realiza de manera tradicional, sin conexión a internet). En cualquier caso, al determinar el alcance es preciso indicar las localizaciones físicas afectadas (oficinas, departamentos), las funciones que quedan incluidas y también los elementos tecnológicos cubiertos. Estos últimos se pueden definir por ejemplo mediante un diagrama de red.

Requisitos de documentación

La documentación del sistema de gestión de seguridad de la información **deberá incluir la política, alcance y objetivos del SGSI,** así como los **diferentes procedimientos y controles** de seguridad del sistema.

La documentación será más o menos amplia dependiendo de la organización y de las diferentes actividades que desarrolle. Por tanto, el alcance y complejidad de los

© Universidad Internacional de La Rioja (UNIR)

requerimientos de seguridad variarán en función de estas circunstancias.

La dirección debe aprobar un **documento de política de seguridad de la información,** que deberá publicar y comunicar a todos los empleados y entidades externas relevantes.

Se deben aprobar los documentos previamente a su distribución, revisando y actualizando los documentos según las necesidades requeridas, y siempre que se garantice que los documentos están periódicamente actualizados.

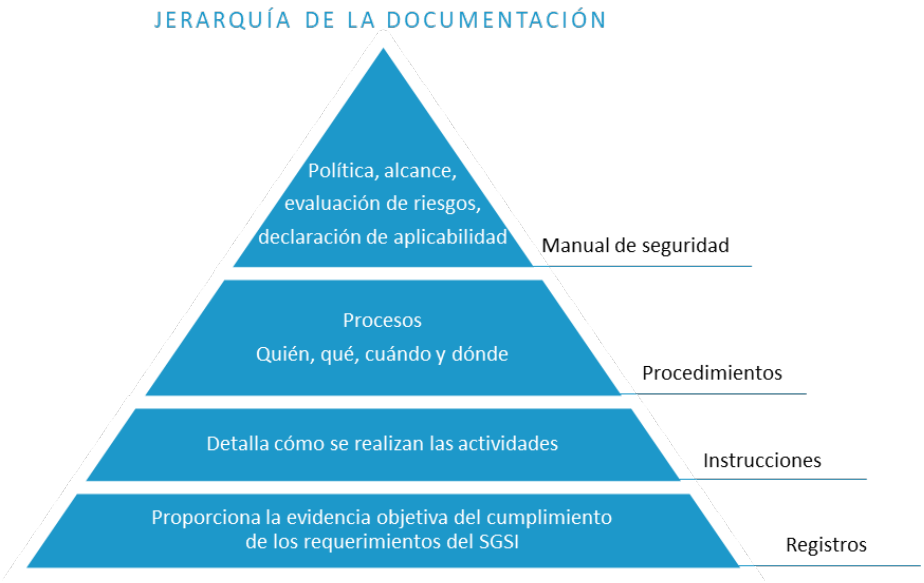


Figura 3. Jerarquía de la documentación. Fuente: elaboración propia.

Compromiso de la dirección

La Norma ISO 27001 especifica la **obligación de suministrar evidencias del compromiso planteado,** tanto en el desarrollo como en la implantación y mejora del sistema, en los siguientes aspectos:

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- En el **proceso de comunicación interna** al personal de la organización de la gestión de la seguridad de la información en la empresa.
- En el **establecimiento de la política y los objetivos** del sistema de gestión de seguridad de la información de la empresa.
- En la **revisión periódica** del desempeño del sistema de gestión.
- En el **aseguramiento de la disponibilidad de los recursos** necesarios para la plena efectividad del sistema.

© Universidad Internacional de La Rioja (UNIR)

Responsabilidades

L a s **responsabilidades** y sus correspondientes autoridades deben estar **perfectamente definidas** en cualquier organización o empresa.

La Norma ISO requiere que **la alta dirección asegure que se cumplan estos requisitos** y que las responsabilidades sean comunicadas dentro de la organización, valorando el tamaño, complejidad y cultura de la organización.

Se puede nombrar un representante de la dirección que tendrá la responsabilidad de:

- Asegurar que los procesos del sistema de gestión de seguridad de la información **se implanten y funcionen.**
- Informar a la alta dirección sobre el **desempeño del sistema** y de cualquier **oportunidad de mejora.**

Revisión por la dirección

La dirección debe desarrollar una **actividad de revisión** que implique la **verificación de la eficacia y efectividad** del sistema de gestión de seguridad de la información para asegurar su plena validez.

El proceso de revisión por la dirección no debería ser un planteamiento realizado solamente para satisfacer los requisitos de la norma o de los auditores, sino que debería ser una parte integral de los procesos de gestión de la organización.

© Universidad Internacional de La Rioja (UNIR)

Versiones del estándar ISO 27001

El estándar ha tenido varias versiones desde la publicación por primera vez del BS 7799 en 1995. Ha sufrido cambios significativos que lo han adaptado para adecuarse según la evolución de los sistemas de información y las tecnologías.

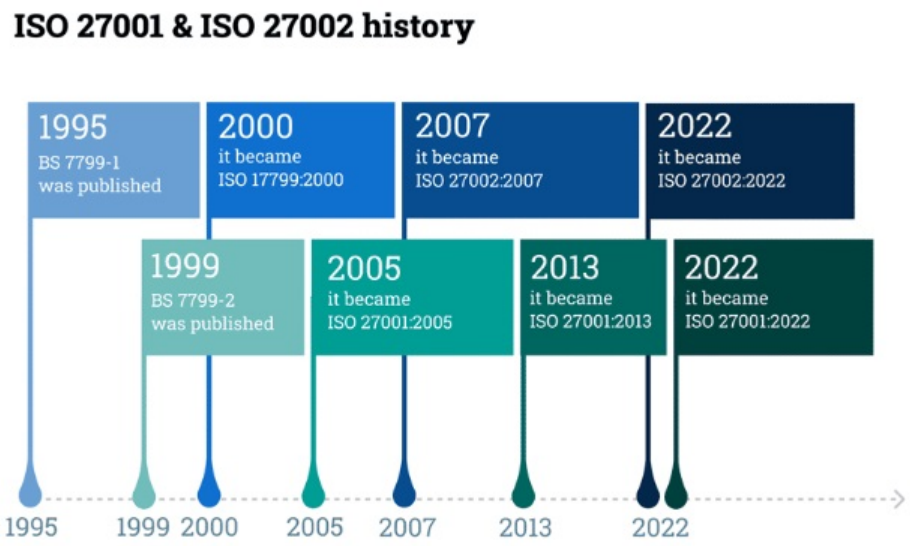


Figura 4. Versiones del estándar ISO 27001.

En 2005 el estándar pasa a definirse bajo la familia de la ISO 27000, definiendo un total de 11 dominios, 39 objetivos de control y 133 controles. En 2007 se introducen cambios menores sobre la versión de 2005.

En 2013 el estándar sufre otra actualización importante, pasando a comprender 14 dominios, 35 objetivos de control y 114 controles. En la versión de 2017 se hicieron correcciones menores respecto a la versión de 2013. El número de dominios, objetivos de control y controles se mantiene con respecto a la versión de 2013.

En octubre de 2022 se publica una nueva versión de la ISO 27001, la cual incluye

© Universidad Internacional de La Rioja (UNIR)

cambios en el cuerpo de esta, así como en el Anexo A (controles ISO 27002).

ISO 27001: 2022

El estándar ISO 27001:2022 introduce cambios significativos frente a sus versiones predecesoras.



Figura 5. Cambios introducidos en la versión de 2022.

Entre los cambios introducidos destacan los siguientes:

- Alineación de la definición de los procesos y sus interacciones con las mejores prácticas de los sistemas de gestión.
- Es necesario comunicar y hacer conocer los roles de seguridad a toda la organización.
- Énfasis en la monitorización de objetivos de seguridad y la planificación de los cambios en el SGSI.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- La revisión por parte de la dirección debe tener en cuenta los cambios en las necesidades de los *stakeholders*.
- Reestructuración de la numeración para acercarla a la estructura de alto nivel.
- En la cláusula 4.4. hay un requisito explícito para definir los procesos y sus interacciones. Esto lo alinea con las mejores prácticas de los sistemas de gestión que indican que estos deben de construirse alrededor de los procesos y de sus interacciones.
- En la cláusula 5.3. se explicita la necesidad de comunicar los roles relevantes en seguridad de la información en toda la organización.
- Respecto de la cláusula 6.2., la ISO 27001 hace referencia explícita a la monitorización de los objetivos de seguridad de la información.
- La cláusula 6.3. nos indica que hay que planificar los cambios del sistema de gestión y que estos se realicen de manera controlada, de manera que exista un plan de cómo estos se van a implementar y validar.
- En la sección 8 se vuelve a remarcar la gestión por procesos del sistema de gestión de seguridad de la información. En la cláusula 8.1. se especifica lo siguiente: «establecer criterios para los procesos y aplicar el control de los mismos».
- En la revisión por parte de la dirección se deben tener en cuenta los cambios en las necesidades y expectativas de las partes interesadas que son relevantes para el SGSI.

En cuanto al Anexo A (listado de controles detallados en la ISO 27002), los cambios son los siguientes:

© Universidad Internacional de La Rioja (UNIR)

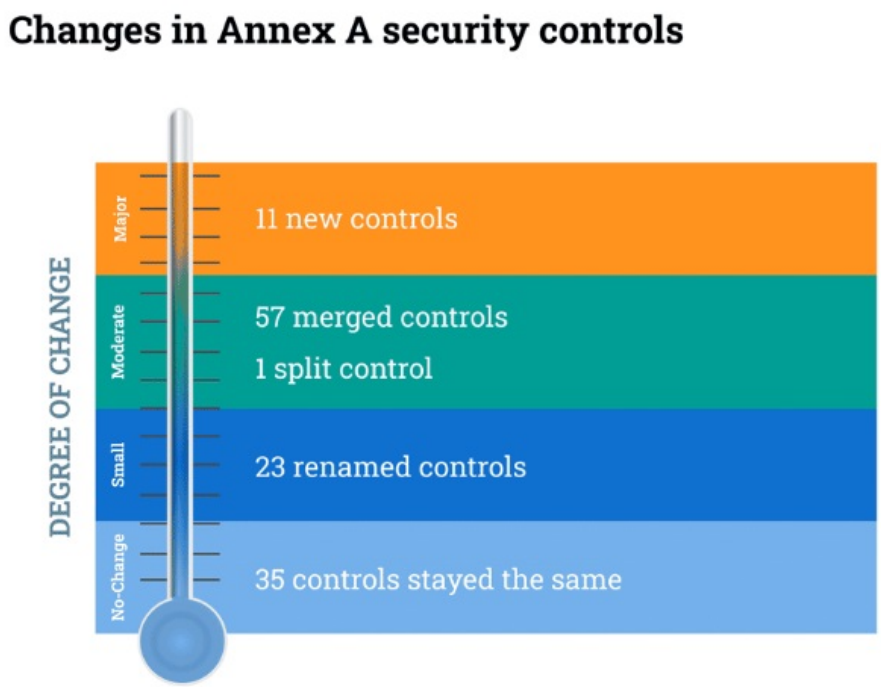


Figura 6. Cambios introducidos en el Anexo A de la versión de 2022.

Para esta nueva versión se disponen de 93 controles frente a los 114 de la versión de 2013. Se modifican los dominios por grupos, de forma que pasan de 14 a 4:

- **Controles organizacionales**: 37 controles (34 existentes / 3 nuevos).
- **Controles relativos a personas**: 8 controles (8 existentes).
- **Controles físicos**: 14 controles (13 existentes / 1 nuevo).
- **Controles tecnológicos**: 34 controles (27 controles existentes / 7 nuevos).

Hay 11 controles nuevos, 24 se han fusionado, 58 se han revisado y 35 se

© Universidad Internacional de La Rioja (UNIR)

mantienen sin cambios.

Adicionalmente, los controles se definen en base a 5 atributos:

- **Tipo de control**: evalúa cuándo y cómo el control modifica el riesgo con respecto a la ocurrencia de un incidente de seguridad de la información. Los controles pueden clasificarse como preventivos, correctivos o predictivos.
- **Propiedades de la seguridad de la información**: identifica qué característica de la información contribuirá a preservar el control. Estas son confidencialidad, integridad o disponibilidad.
- **Conceptos de ciberseguridad**: asocian los controles a los conceptos de ciberseguridad descritos en ISO/IEC TS 27110 y usados en otros marcos de trabajo, como NIST-Cibersecurity Framework: identificar, proteger, detectar, responder y recuperar.
- **Capacidad operativa**: atributo para ver los controles desde la perspectiva del profesional de las capacidades de seguridad de la información: gobernanza, gestión de activos y protección de la información.
- **Dominios de seguridad**: atributo que permite ver los controles desde la perspectiva de cuatro dominios de seguridad de la información: gobernanza y ecosistema, protección, defensa y resiliencia.

Los nuevos controles introducidos en esta versión incluyen los siguientes:

© Universidad Internacional de La Rioja (UNIR)



Figura 7. Nuevos controles introducidos en la versión 2022.

© Universidad Internacional de La Rioja (UNIR)

3.3. Modelos de madurez para la seguridad de la información

Un **modelo de madurez** sirve para **situar y evaluar el grado de desarrollo de una gestión sistemática, predecible y optimizable.** Estos modelos se han popularizado en el contexto del desarrollo de *software,* pero poco a poco han sido adaptados a otros dominios, incluyendo el de la seguridad de la información.

En lo que sigue introducimos uno de esos modelos, el **CMMI,** quizá el más conocido y extendido en la actualidad. Es importante tener en cuenta que las ideas del CMMI se han aplicado recientemente a los servicios.

Posteriormente describimos un modelo de madurez específico de la seguridad de la información.

El modelo de madurez CMMI

El modelo CMMI, acrónimo del inglés *Capability Madurity Model Integration,* es una evolución de un modelo anterior denominado CMM inicialmente desarrollado por el Instituto de Ingeniería del Software (SEI) de la Universidad Carnegie Mellon.

El SEI llevó a cabo el encargo de desarrollar un modelo de calidad que sirviera como base para establecer un sistema de capacitación de las compañías que suministraban software al gobierno de los Estados Unidos. Dicho modelo fue definido como:

© Universidad Internacional de La Rioja (UNIR)

> «Un enfoque para la mejora de procesos que proporciona a una organización los elementos esenciales para llevar a cabo sus procesos de manera efectiva. Puede utilizarse para guiar la mejora de procesos en un proyecto, en un departamento, o en una organización completa. CMMI ayuda a integrar funciones de la organización tradicionalmente separadas, a establecer prioridades y objetivos en la mejora de procesos, proporciona guías para los procesos de calidad y sirve como punto de referencia para la evaluación de los procesos actuales».

Nótese que CMMI no es un proceso de desarrollo de software, sino más bien una **guía que describe las características que hacen efectivo a un proceso.** Las ideas que aporta pueden ser, por tanto, utilizadas como un conjunto de buenas prácticas, como un marco para la organización y priorización de actividades, o como una forma de alinear los objetivos de la organización con los objetivos del proceso en estudio.

CMMI se interesa por la mejora de los procedimientos y métodos (procesos) que las personas de una organización llevan a cabo con ayuda de tecnología y otras herramientas, ya que, si los procesos no están correctamente definidos, son maduros y ampliamente conocidos, ni las más cualificadas personas serán capaces de rendir a su mejor nivel aun disponiendo de las mejores herramientas.

El modelo O-ISM3

El *Open Group* desarrolló un modelo de madurez denominado *Open Group Security Management Maturity Model* (O-ISM3), que permite **el diseño de sistemas de gestión de la seguridad alineados con la misión de la organización empresarial** y el cumplimiento de las necesidades.

© Universidad Internacional de La Rioja (UNIR)

Puedes encontrar más información sobre el Open Group y el modelo O-ISM3 en las siguientes direcciones web:
http://www.opengroup.org/
https://www2.opengroup.org/ogsys/jsp/publications/PublicationDetails.jsp?publicationid=12238

La nueva norma permite a las organizaciones **priorizar y optimizar las inversiones en seguridad de la información,** así como permitir la mejora continua de los sistemas que utilizan métricas bien definidas.

El modelo se basa en la consideración de tres elementos fundamentales en la seguridad de la información:

- Gestión de riesgos
- Controles de seguridad.
- Gestión de la seguridad, mediante un sistema de políticas y herramientas que las implementan.

Por otro lado, el estándar se basa en las siguientes definiciones:

- **Proceso:** los procesos tienen capacidades que se realizan mediante prácticas de gestión.
- **Capacidad:** las métricas de un proceso revelan las capacidades de este.
- **Madurez** (grado de): ciertos conjuntos de procesos seleccionados según ciertas capacidades permiten clasificar a la organización en un nivel de madurez.

Otros modelos de madurez

© Universidad Internacional de La Rioja (UNIR)

Existen modelos de madurez adicionales como son:

- **Modelo de Madurez de Seguridad de la Información (ISM) de CERT/CC**: desarrollado por el CERT Coordination Center (CERT/CC) de la Universidad Carnegie Mellon. Ofrece un enfoque integral para evaluar y mejorar la seguridad de la información en una organización.

- **Modelo de Madurez de Seguridad de NIST (CSF)**: desarrollado por el Instituto Nacional de Estándares y Tecnología (NIST) de EE. UU. Proporciona un enfoque basado en riesgos para gestionar y mejorar la seguridad de la información.

- **Marco de Ciberseguridad de la Unión Europea (EU NIS)**: establecido por la Unión Europea para mejorar la ciberseguridad. Viene articulado en el marco de la Directiva sobre Seguridad de las Redes y de la Información (NIS, por sus siglas en inglés) de la Unión Europea. La Directiva NIS es una legislación de la UE diseñada para mejorar la ciberseguridad en los Estados miembros y asegurar un alto nivel común de seguridad de la red y la información en la Unión Europea. Proporciona un marco para evaluar la madurez de la ciberseguridad en sectores que se consideran clave.

- **Modelo de Madurez de Seguridad Empresarial (BSIMM)**: desarrollado por la Iniciativa de Medición de la Madurez de la Seguridad Empresarial (BSIMM). Está más enfocado en el desarrollo de *software*, pero también es considerado un modelo de madurez.

© Universidad Internacional de La Rioja (UNIR)

3.4. Referencias bibliográficas

International Organization for Standardization. (2013). Information technology — Security techniques — Information security management systems — Requirements (estándar ISO 27001:2013). https://www.iso.org/standard/54534.html

© Universidad Internacional de La Rioja (UNIR)

Vídeos introductorios a ISO 27001

Certification Europe. (25 de septiembre de 2011). *ISO 27001 Information Security Management Certification Accreditation Overview (Part 1/18)* [Vídeo]. YouTube. https://www.youtube.com/watch?v=V7T4WVWvAA8&list=PL5E6D4A5B33DCAE78

Esta serie de vídeos introduce los conceptos de ISO 27001 contados por expertos en el área. Es una serie de vídeos cortos introductorios especialmente recomendados mientras se está estudiando la norma.

© Universidad Internacional de La Rioja (UNIR)

Norma UNE ISO 27001

International Organization for Standardization. (2013). Information technology — Security techniques — Information security management systems — Requirements (estándar ISO 27001:2013). https://www.iso.org/standard/54534.html

La norma ISO 27001 establece los requisitos para la certificación de los SGSI. Como tal, es muy importante conocer sus contenidos y definiciones.

© Universidad Internacional de La Rioja (UNIR)

Web informativa de la familia de estándares ISO 27000

The ISO 2700 Directory. (S. f.). An Introduction to ISO 27001, ISO 27002… ISO27008. http://www.27000.org/index.htm

Esta web ofrece información general de la familia de estándares.

© Universidad Internacional de La Rioja (UNIR)

1. Indica cuáles de los siguientes enunciados son dominios de la ISO 27001:2013:

   A. Seguridad física y ambiental.

   B. Análisis y gestión de riesgos.

   C. Evaluación del desempeño.

   D. Todos los anteriores.

2. Indica cuáles de las siguientes opciones son capítulos de la ISO 27001:2013:

   A. Alcance.

   B. Planificación.

   C. Mejora.

   D. Todos los anteriores.

3. Indica cuáles de las afirmaciones siguientes son ciertas sobre el estándar 27001:

   A. ISO 27001 define en detalle el proceso de gestión del riesgo de un Sistema de Gestión de la Seguridad de la Información.

   B. ISO 27001 define la base y los conceptos para la auditoría y certificación de los Sistemas de Gestión de la Continuidad del Negocio.

   C. ISO 27001 considera como uno de los elementos fundamentales el compromiso de la dirección, requisito para el establecimiento de un Sistema de Gestión de la Seguridad de la Información.

   D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

4. Indica cuál de los siguientes aspectos está contemplado por la ISO 27001:

A. La definición de los objetivos de negocio de la compañía.

B. El nombramiento de un comité específico y único para la continuidad del negocio.

C. La implantación de un modelo organizativo corporativo que unifique las áreas de seguridad física y seguridad lógica en una sola.

D. La ubicación adecuada de las copias de respaldo.

5. Indica cuáles de las siguientes afirmaciones permiten evidenciar el compromiso de la dirección con la gestión de la seguridad:

A. La dedicación de una partida presupuestaria específica para aspectos de Seguridad de la Información.

B. La participación de la dirección en comités de seguridad y actas relacionadas con la toma de decisiones en seguridad.

C. La definición de una política de seguridad general distribuida a todos los empleados de la organización.

D. Ninguna de las anteriores.

6. Indica cuál de las siguientes afirmaciones es cierta:

A. La última versión de la ISO 27001 se basa en un modelo PDCA de mejora continua.

B. Según ISO 27001, la adopción de un Sistema de Gestión de la Seguridad de la Información debe estar motivada por decisiones tácticas referentes a la mejora de los costes asociados con la seguridad.

C. Según ISO 27001, el Sistema de Gestión de la Seguridad de la Información debe comprender a toda la organización, para garantizar que no existe ninguna posibilidad de intrusión en ninguno de sus niveles.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

7. Indica cuáles de las siguientes afirmaciones son ciertas:

A. Según ISO 27001, los registros no son evidencia objetiva sobre el cumplimiento de los requisitos del Sistema de Gestión de la Seguridad de la Información.

B. Según ISO 27001, el apoyo explícito y formal de la dirección solo será necesario si la organización no cuenta con la suficiente madurez en seguridad de la información.

C. La política de seguridad de la información es el documento que debe comunicarse a toda la empresa y a partir del cual se deriva el resto de los requisitos del sistema.

D. Ninguna de las anteriores.

8. Indica cuál de las siguientes afirmaciones es cierta:

A. El modelo CMMI define 5 niveles de madurez iniciales, pero pueden ser configurables según las necesidades de la compañía.

B. Según CMMI, en un nivel de madurez definido la organización está trabajando con datos cuantitativos para determinar procesos predecibles que se alinean con las necesidades de las partes interesadas.

C. Según CMMI, en un nivel de madurez optimizado se hace uso intensivo de las métricas, se gestiona el proceso de innovación y la organización completa está volcada en la mejora continua de los procesos.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

9. Indica cuál de las siguientes afirmaciones es cierta:

A. El modelo CMMI permite medir el nivel global de madurez de los controles técnicos de una organización.

B. El modelo CMMI permite medir el nivel de capacidad de un área de proceso en una organización.

C. Según CMMI, en un nivel de madurez inicial el proceso está bien definido, pero aún no está gestionado.

D. Ninguna de las anteriores.

10. Indica cuáles de los siguientes son elementos fundamentales para la definición del nivel de madurez de una organización de acuerdo con O-ISM3:

A. Gestión de riesgos.

B. Controles de seguridad.

C. Gestión de la seguridad.

D. Todos los anteriores.

© Universidad Internacional de La Rioja (UNIR)